



Lecture 1 – Introduction & Physical Layer (Deep Analysis)

◆ 1. Core Concepts

The Physical Layer (Layer 1 of the OSI Model) is responsible for the **raw transmission of bits** over a medium. It defines:

- Electrical/optical/radio **signal properties**
- **Cable types**, connectors, and voltages
- **Bit rate**, encoding schemes
- **Medium access control basics**

It does **not** understand addresses, packets, or protocols — it just transmits bits as signal pulses.

◆ 2. Technical Mechanisms

◆ Signaling

Bits are converted into electrical or optical signals using:

- **NRZ (Non-Return-to-Zero)** encoding
- **Manchester encoding** (clock + data in one signal)
- **Baseband or broadband** transmissions

◆ Transmission Media

Type	Description	Common Use
UTP/STP	Twisted pair copper cables	Ethernet (Cat5/Cat6)
Fiber Optic	Light pulses over glass fibers	High-speed backbones
Wireless	RF signals (Wi-Fi, Bluetooth)	Mobile, wireless LAN

◆ Devices

- **NIC (Network Interface Card)**: Converts bits <-> signals
- **Repeaters**: Re-amplify signal over distance
- **Hubs**: Simple repeaters that forward signals blindly

◆ Bit Synchronization

Essential for interpreting when a bit starts/stops:

- Achieved via clock recovery (e.g., PLL circuits)
- Manchester encoding helps synchronization

◆ 3. Vulnerabilities & Threats

Threat Type	Description	Example
Eavesdropping	Physical tap on cable or antenna	Attacker listens to unencrypted Wi-Fi or Ethernet
Jamming	Noise injected into RF signals	Denial of Wi-Fi service
Signal Reflection	Poor cabling causes echoes	Data corruption
Interference	EMI from power lines, motors	Degrades signal integrity

Physical layer attacks are **passive (e.g. sniffing)** or **disruptive (e.g. jamming)**.

◆ 4. Defenses and Controls

- **Shielded cables:** Reduce EMI (STP instead of UTP)
- **Encryption at higher layers:** TLS, IPSec
- **Physical security:** Locked wiring closets, tamper detection
- **Wi-Fi security protocols:** WPA3 instead of open/WEP
- **Signal filtering:** Prevents reflection and overreach

Note: Physical layer lacks protocol-level encryption or validation.

◆ 5. Exam Practice (with Answers)

Q1: What is the role of the physical layer in the OSI model?

A: It transmits raw bitstreams over a medium as electrical, optical, or RF signals without interpreting the data.

Q2: What kinds of attacks are possible at Layer 1?

A: Eavesdropping (sniffing), jamming, signal interference, physical tapping.

Q3: How can you defend against jamming in wireless networks?

A: Use spread spectrum techniques, frequency hopping, and switch to wired backup if critical.

Q4: Why is encryption not a defense at Layer 1?

A: Layer 1 transmits raw signals; encryption is applied at higher layers (e.g., TLS at Layer 6/7).

Q5: Give an example where physical layer vulnerability leads to security failure.

A: An attacker installs a tap on an Ethernet cable in a building's server room and records unencrypted packets.

End of Lecture 1 Deep Analysis.

Lecture 2 – Data Link Layer (Deep Analysis)

◆ **1. Core Concepts**

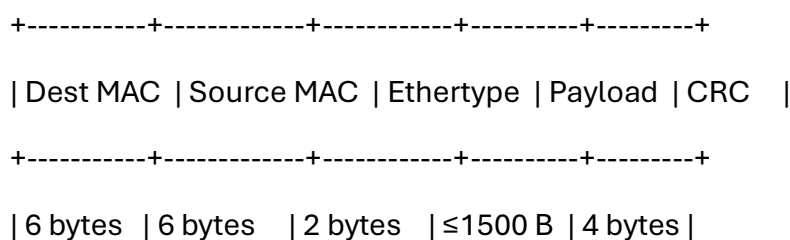
The **Data Link Layer (Layer 2)** ensures reliable point-to-point communication over the physical medium. It deals with:

- **Framing:** Encapsulating network layer packets into frames
- **MAC addressing:** Identifying devices on the same LAN
- **Error detection:** CRC, parity
- **Access control:** Determines which device can transmit (CSMA/CD, CSMA/CA)

It handles **node-to-node delivery** within the same local network.

◆ **2. Technical Mechanisms**

◆ **Frame Structure (Ethernet II)**



- **Ethertype:** 0x0800 = IPv4, 0x86DD = IPv6
- **CRC:** Error detection via cyclic redundancy check

◆ MAC Addressing

- 48-bit unique identifier: 00:11:22:33:44:55
- First 3 bytes = vendor (OUI)
- Last 3 bytes = device-specific

◆ ARP (Address Resolution Protocol)

- Maps IP to MAC address in local networks
- ARP request: broadcast
- ARP reply: unicast with matching MAC

◆ Switching & CAM Table

- **Switches** store MAC-port mappings in the CAM table
- If unknown MAC: flood to all ports (except ingress)
- If CAM overflows: switch enters hub mode → security risk

◆ 3. Vulnerabilities & Attacks

Attack	Description
--------	-------------

ARP Spoofing	Attacker poisons ARP cache, impersonates gateway
--------------	--

MAC Flooding	Overload switch's CAM → forces flooding
--------------	---

VLAN Hopping	Crafting packets to cross VLAN boundaries
--------------	---

Sniffing	Capture traffic in promiscuous mode
----------	-------------------------------------

Example - ARP Spoofing Packet:

Sender MAC: Attacker's MAC

Sender IP: 192.168.1.1 (gateway IP)

Target MAC: Victim

Target IP: Victim's IP

◆ 4. Defenses and Controls

- **Port security:** Limit MAC addresses per port

- **Dynamic ARP Inspection (DAI):** Filters spoofed ARP packets
- **Static ARP entries:** Prevent spoofing (only feasible on small networks)
- **802.1Q VLAN tagging:** Prevents VLAN hopping when configured properly
- **Network segmentation:** Reduces exposure surface

Tooling: arpswatch, snort, Wireshark, ettercap, macof

◆ 5. Exam Practice (with Answers)

Q1: What does the data link layer do that the physical layer does not?

A: It frames data, performs MAC addressing, and handles local delivery and error detection, unlike the physical layer which only transmits raw bits.

Q2: How does ARP spoofing compromise a LAN?

A: The attacker tricks devices into sending traffic to their MAC by responding to ARP requests with spoofed IP-MAC mappings, enabling MITM.

Q3: What is a CAM overflow attack and what are its effects?

A: Overloading a switch's MAC table causes it to behave like a hub, forwarding all frames to all ports — enabling sniffing.

Q4: How does port security help in mitigating layer 2 threats?

A: It restricts the number and identity of MAC addresses per switch port, preventing MAC spoofing and flooding.

Q5: What is the risk of misconfigured VLANs?

A: Improper tagging or lack of filtering can allow attackers to inject packets into other VLANs (VLAN hopping).

End of Lecture 2 Deep Analysis.

Lecture 3 – Network Layer (Deep Analysis)

◆ 1. Core Concepts

The **Network Layer (Layer 3)** handles end-to-end communication between different networks. It determines **routing**, **IP addressing**, and **packet forwarding**.

Main responsibilities:

- Logical addressing (IPv4, IPv6)
- Routing between networks

- Packet fragmentation and reassembly
 - Error reporting and diagnostics (ICMP)
-

◆ 2. Technical Mechanisms

◆ IP Packet Format (IPv4)

```
+-----+-----+-----+-----+
| Version (4) | Header Len | DSCP/ECN | Total Len |
| Identification | Flags | Fragment Offset |
| TTL | Protocol | Header Checksum |
| Source IP Address |
| Destination IP Address |
| (Options) |
| Payload (e.g., TCP/UDP) |
+-----+
```

- **Protocol field:** 1 = ICMP, 6 = TCP, 17 = UDP
- **TTL:** Decreased at each hop to prevent loops
- **Fragment Offset:** Used in fragmentation/reassembly

◆ ICMP

- Used for diagnostics (ping, traceroute)
- Types: Echo request/reply, Destination unreachable, Time exceeded
- Often used in scanning & tunneling (covert channels)

◆ Routing

- Routers forward packets based on destination IP and routing table
 - May perform NAT (Network Address Translation)
 - Routing protocols: OSPF, BGP
-

◆ 3. Vulnerabilities & Attacks

Attack	Description
IP Spoofing	Source IP is faked to impersonate or bypass filters
Teardrop	Overlapping fragments crash older OS kernels
Ping of Death	Oversized ICMP packets cause buffer overflow
ICMP Tunneling	Encodes payloads in ICMP for stealth communication
Source Routing	Attacker sets packet path, bypassing security policies

◆ 4. Defenses and Controls

- **Ingress filtering:** Block spoofed source IPs at the edge
- **Fragmentation control:** Drop malformed or overlapping fragments
- **ICMP rate limiting:** Prevent abuse in tunneling/scanning
- **Disable source routing** on routers and hosts
- **Use firewall rules:** Block unnecessary ICMP types

Tools: iptables, nftables, Wireshark, Snort, netstat

◆ 5. Exam Practice (with Answers)

Q1: What is the purpose of the TTL field in IP packets?

A: It limits the lifespan of a packet to prevent infinite routing loops; each router decrements TTL by 1.

Q2: What does an attacker gain from IP spoofing?

A: It allows impersonation, evasion of filters, and launching attacks anonymously (e.g., SYN floods).

Q3: How does the teardrop attack exploit IP fragmentation?

A: It sends overlapping IP fragments that some OS kernels mishandle, causing crashes.

Q4: Why should source routing be disabled?

A: It allows attackers to control packet path and bypass normal routing/firewall policies.

Q5: What protocol field values indicate TCP, UDP, and ICMP in IP headers?

A: 6 (TCP), 17 (UDP), 1 (ICMP)

End of Lecture 3 Deep Analysis.

Lecture 4 – Transport Layer (Deep Analysis)

◆ **1. Core Concepts**

The **Transport Layer (Layer 4)** ensures reliable or fast end-to-end communication between applications on different hosts. Its two main protocols are:

- **TCP (Transmission Control Protocol)** – reliable, ordered
- **UDP (User Datagram Protocol)** – fast, connectionless

Responsibilities:

- Port addressing
- Connection management (TCP)
- Error detection and retransmission (TCP)
- Multiplexing of application data

◆ **2. Technical Mechanisms**

◆ **TCP Header Format**

```
+-----+-----+
| Source Port | Destination Port |
| Sequence Number          |
| Acknowledgment Number    |
| Data Offset | Flags | Window Size |
| Checksum    | Urgent Pointer  |
| (Options)           |
+-----+-----+
```

Flags:

- SYN: Start connection
- ACK: Acknowledge
- FIN: Close connection

- RST: Reset

♦ TCP 3-Way Handshake

1. Client → Server: SYN (Seq=x)
2. Server → Client: SYN-ACK (Seq=y, Ack=x+1)
3. Client → Server: ACK (Ack=y+1)

♦ UDP Header Format

```
+-----+-----+
| Source Port | Destination Port |
| Length     | Checksum       |
+-----+-----+
```

♦ 3. Vulnerabilities & Attacks

Attack	Description
SYN Flood	Sends many half-open SYNs to exhaust server resources
TCP Hijacking	Predicts sequence numbers to inject into a session
TCP RST Attack	Sends forged RST to terminate connections
LAND Attack	SYN from same IP/port to same IP/port (self-loop)
UDP Reflection	Spoofed UDP requests trigger large replies to victim

♦ 4. Defenses and Controls

- **SYN cookies:** Delay allocation of connection state
- **Timeouts:** Drop half-open connections quickly
- **Randomized ISN:** Prevent hijacking
- **Firewall rules:** Filter invalid or suspicious flags
- **UDP rate limiting:** Throttle reflected attack volumes

Tools: hping3, nmap, Wireshark, iptables, netstat, tcpdump

◆ 5. Exam Practice (with Answers)

Q1: What does TCP provide that UDP does not?

A: TCP ensures ordered, reliable delivery with flow and congestion control. UDP is connectionless and faster but unreliable.

Q2: What happens in a SYN flood?

A: The attacker sends many SYNs with spoofed IPs; the server allocates memory for connections that never complete.

Q3: How does TCP hijacking work?

A: The attacker observes a TCP session and injects data by guessing sequence numbers, taking over the connection.

Q4: What is the purpose of SYN cookies?

A: To prevent SYN flood exhaustion by encoding connection data in the SYN-ACK without storing state on the server.

Q5: Give an example of a UDP reflection service.

A: DNS or NTP servers that reply to small queries with large responses, which can be abused for amplification in DoS attacks.

End of Lecture 4 Deep Analysis.

Lecture 5 – Application Layer (Deep Analysis)

◆ 1. Core Concepts

The **Application Layer (Layer 7)** is where end-user applications communicate over the network. It provides protocols for web, email, DNS, file transfer, etc.

Key responsibilities:

- User interface communication
- Data formatting (HTTP, SMTP, DNS)
- Application-specific logic and sessions
- Authentication and data integrity (often via TLS)

◆ 2. Technical Mechanisms

◆ Key Protocols

Protocol Purpose		Common Ports
HTTP	Web browsing	80 (HTTP), 443 (HTTPS)
DNS	Domain resolution	53 (UDP/TCP)
SMTP	Email sending	25 (TCP)
FTP	File transfer	20/21 (TCP)
TLS	Secure communications	Depends on app layer

◆ HTTP Request Example

GET /index.html HTTP/1.1

Host: www.example.com

User-Agent: Mozilla/5.0

◆ DNS Query Example

Header: Transaction ID + Flags

Question: www.example.com, Type A

Answer: IP address (if cached or resolved)

◆ TLS Structure (Simplified)

- Handshake: cert exchange, key negotiation
- Record Layer: encrypted messages (e.g., HTTP over TLS)

◆ 3. Vulnerabilities & Attacks

Attack	Description
DNS Spoofing	Attacker injects fake IP for domain
DNS Cache Poisoning	Poison resolver cache with wrong IP mapping
Phishing	Deceptive websites mimic real ones
SSL Stripping	Downgrade HTTPS to HTTP
Heartbleed	TLS buffer over-read leak
Man-in-the-Middle	Intercept & modify communication

◆ 4. Defenses and Controls

- **DNSSEC:** Validates DNS records with signatures
- **Strict Transport Security (HSTS):** Forces HTTPS
- **TLS Certificates:** Ensure authenticity and integrity
- **Input validation:** Prevent injection, XSS, CSRF
- **Secure configurations:** Disable old protocols (SSLv2/3, TLS < 1.2)
- **Firewall/Proxy:** Enforce HTTP policies, block spoofed DNS responses

Tools: dig, nslookup, Wireshark, browser dev tools, openssl, curl -v

◆ 5. Exam Practice (with Answers)

Q1: What does the application layer provide in the OSI model?

A: It enables user-level applications to communicate using standardized protocols (e.g., HTTP, SMTP, DNS).

Q2: How does DNS cache poisoning work?

A: An attacker tricks a resolver into storing a fake IP mapping for a domain, redirecting users to malicious sites.

Q3: What is SSL stripping and how is it mitigated?

A: Downgrading a secure HTTPS connection to HTTP; mitigated using HSTS headers and only accepting HTTPS.

Q4: Why is TLS used?

A: TLS provides encryption, integrity, and authentication for application-level traffic.

Q5: What is the danger of outdated TLS versions?

A: They may lack modern protections (e.g., no forward secrecy) and be vulnerable to attacks like POODLE or BEAST.

End of Lecture 5 Deep Analysis.



Lecture 6 – Cyber Threat Intelligence (Deep Analysis)

◆ 1. Core Concepts

Cyber Threat Intelligence (CTI) refers to the collection, processing, and analysis of information about potential or current threats targeting digital assets. CTI improves decision-making for defense, detection, and response.

Three levels of CTI:

- **Strategic** – high-level motives, long-term impact (e.g., geopolitical, economic)
- **Operational** – attacker TTPs (tools, techniques, procedures)
- **Tactical** – low-level technical indicators (IPs, hashes, domains)

◆ 2. Technical Mechanisms

◆ Indicators of Compromise (IoCs)

- IP addresses, file hashes, URLs, domain names
- Used in firewalls, IDS/IPS, SIEM systems to detect malicious activity

◆ TTPs (MITRE ATT&CK Framework)

- Maps attacker behavior to known tactics
- Example: "Spearphishing Attachment" → Delivery → Malware Execution

◆ Pyramid of Pain (David Bianco)

Level	Example	Difficulty to Change
Hashes	File signatures	Easy (low pain)
IPs/Domains	IOC lists	Easy/Medium
Network Artifacts	URLs, headers	Harder
Host Artifacts	Registry keys	Harder
Tools	CobaltStrike	High
TTPs	Full behavior	Very High (max pain)

◆ CTI Sharing Platforms

- MISP, STIX/TAXII, ISACs
 - Enable collaboration between orgs
-

◆ 3. Threats & Exploitable Issues

Issue	Description
Blind spots	No monitoring on certain segments/logs
Over-reliance on IoCs	Attackers rotate indicators frequently
Late detection	Lacking behavioral correlation
Context-less alerts	Lacking operational/strategic intel

CTI Misuse Risks:

- Data overload without context
- False positives
- Attribution mistakes (e.g., blaming wrong APT group)

◆ 4. Defensive Strategy

- Combine all three CTI levels: tactical, operational, strategic
- Automate IOC integration into IDS/IPS and SIEM
- Correlate telemetry with known TTPs
- Maintain CTI feeds + human analysis
- Share threat data with trusted partners

Tools:

- SIEM: Splunk, QRadar
- Threat Feeds: Anomali, VirusTotal, AlienVault OTX
- Threat Intel Platforms: MISP, CRITS

◆ 5. Exam Practice (with Answers)

Q1: What is the difference between tactical and operational threat intelligence?

A: Tactical is technical indicators (IPs, hashes), while operational covers attacker behavior and TTPs.

Q2: Why are TTPs harder to evade than hashes or IPs?

A: TTPs reflect attacker methodology; changing them requires retooling and retraining, unlike IPs/hashes.

Q3: What does the Pyramid of Pain illustrate?

A: The higher up you detect (e.g., TTPs), the more painful it is for the attacker to adapt.

Q4: What is a downside of relying too much on IoCs?

A: They become outdated quickly and may cause false negatives or miss novel threats.

Q5: Why is CTI sharing important?

A: It improves collective security, accelerates detection of threats, and avoids duplication of effort.

End of Lecture 6 Deep Analysis.



Lecture 7 – Internet Security & BGP (Deep Analysis)

◆ 1. Core Concepts

This lecture focuses on **inter-domain routing security** and how the internet exchanges data using **BGP (Border Gateway Protocol)**. It explains the structure of the global internet, the vulnerabilities in BGP, and mechanisms for abuse and defense.

Key focus areas:

- BGP route propagation
- Autonomous Systems (AS)
- Prefix hijacking and blackholing
- Large-scale DoS and surveillance via routing

◆ 2. Technical Mechanisms

◆ BGP Basics

- BGP is the routing protocol between ASes
- Each AS has a unique AS number (e.g., AS23456)
- ASes announce ownership of IP prefixes to each other

- Routing decisions made based on path vectors (AS_PATH)

◆ **Route Announcements**

Example:

AS65001 announces 192.0.2.0/24 to AS65002

AS65002 forwards to its neighbors

Routers choose best path based on:

- Shortest AS path
- Local policy

◆ **Blackhole Routing (DoS Defense or Attack)**

- A route is advertised for a specific IP or subnet
- Traffic to that destination is dropped
- Used to mitigate attacks (legit) or perform targeted DoS (malicious)

◆ **3. Vulnerabilities & Attacks**

Attack	Description
BGP Hijacking	AS falsely advertises IP prefix it doesn't own
BGP Blackholing	AS announces route to /32 and silently drops packets
Prefix Deaggregation	Announces smaller subnets to override broader ones
BGP Route Leak	Improper re-announcement of internal prefixes

Real World Example

- In 2008, Pakistan Telecom hijacked YouTube's IP prefix, causing global outages
- In 2018, Google BGP prefixes were hijacked for crypto theft via DNS rerouting

◆ **4. Defenses and Controls**

- **RPKI (Resource Public Key Infrastructure):** Signs prefix-AS pairs with certificates
- **Prefix filtering:** Accept only expected prefixes from peers

- **Max prefix limits:** Protect from route leaks
- **BGP monitoring tools:** RIPE RIS, RouteViews, BGPMon
- **Cooperation & peering agreements:** Enforce responsible announcements

Tools: bgpstream, Bird, Quagga, RIPE Atlas, RPKI Validator

◆ 5. Exam Practice (with Answers)

Q1: What does BGP do in the internet infrastructure?

A: It enables Autonomous Systems to exchange routing information, determining the global path of IP packets.

Q2: What is BGP hijacking and why is it dangerous?

A: An AS falsely claims ownership of IP prefixes, redirecting or dropping traffic. It can enable MITM, DoS, or surveillance.

Q3: How does blackhole routing work?

A: A prefix is announced with a special community; traffic is dropped intentionally either for defense (DoS mitigation) or attack.

Q4: What is RPKI and how does it help?

A: RPKI provides cryptographic validation of which AS is authorized to announce which prefixes, preventing unauthorized announcements.

Q5: Why is prefix filtering important?

A: It ensures that peers cannot announce routes for IP ranges they do not legitimately own or manage.

End of Lecture 7 Deep Analysis.

Network Security Exam Practice & Cheatsheet

◆ Part 1: Full Practice Exam (Advanced, Exam-Style Questions)

✅ Q1. (Layer 2)

You observe unexpected ARP replies in a switched network where port security is enabled. Some devices lose internet access.

a) What attack is likely happening?

Answer: ARP spoofing or ARP cache poisoning.

b) Explain how port security may or may not help here.

Answer: Port security can block devices sending frames with unknown MACs, but ARP spoofing uses valid MACs with spoofed IPs, so it may bypass basic port MAC filters.

c) Suggest a detection and prevention strategy.

Answer: Use Dynamic ARP Inspection (DAI), enable static ARP bindings, monitor ARP packets using Arpwatch or IDS signatures.

✅ Q2. (Layer 3)

A Linux server behind a firewall is reachable via ICMP, but logs show overlapping IP fragments arriving. The server crashes intermittently.

a) Which specific attack matches this pattern?

Answer: Teardrop attack.

b) Why do overlapping fragments cause problems?

Answer: The OS cannot correctly reassemble the packet due to overlapping offsets, leading to kernel panics or buffer overflows.

c) Suggest a way to block this attack at a network perimeter.

Answer: Drop malformed fragments using deep packet inspection on firewalls; enforce fragment reassembly normalization.

✅ Q3. (Layer 4)

An attacker successfully hijacks an active TCP session from outside the LAN.

a) How can TCP hijacking be performed remotely?

Answer: By sniffing sequence numbers (if visible) or guessing them in predictable stacks; then injecting forged packets.

b) What conditions make this feasible?

Answer: Predictable ISNs (initial sequence numbers), no encryption, attacker can intercept traffic (e.g., shared Wi-Fi).

c) How can operating systems defend against this attack?

Answer: Use randomized ISNs, TCP sequence validation, deploy encrypted protocols like SSH instead of Telnet.

✓ Q4. (Application Layer)

A DNS resolver suddenly returns IPs leading to phishing sites. Clients report valid domains resolving incorrectly.

a) What type of attack is this?

Answer: DNS cache poisoning.

b) Explain how this can occur without compromising the client.

Answer: The attacker spoofs DNS replies to the resolver, which caches the forged record, affecting all clients.

c) Name two protective DNS techniques that prevent this.

Answer: DNSSEC and source port + transaction ID randomization.

✓ Q5. (Internet Routing)

AS64551 begins advertising 8.8.8.0/24 to Tier-1 providers. Within minutes, users report inability to reach Google DNS.

a) What is the attack called?

Answer: BGP hijacking.

b) Describe how it affects global routing.

Answer: Routes to the legitimate IP block are redirected to a malicious or null path, breaking global connectivity.

c) What cryptographic protocol can prevent this?

Answer: RPKI (Resource Public Key Infrastructure).

✓ Q6. (Threat Intelligence)

You receive a report from MISP showing 15 domains and 3 IPs linked to a phishing kit campaign. The report includes MITRE ATT&CK TTPs.

a) What level(s) of threat intelligence are included?

Answer: Tactical (IPs/domains) and Operational (TTPs).

b) How does this help your SOC?

Answer: Enables fast deployment of indicators to firewalls/IDS, provides context to understand adversary behavior.

c) Why are TTPs more valuable than IoCs for long-term defense?

Answer: TTPs represent attack behavior, which is harder for adversaries to change compared to rotating IoCs.

◆ Part 2: Cheatsheet Notes (Condensed)

🏗️ OSI Layer Summary

Layer Focus	Key Protocols
7 Apps + UI	HTTP, DNS, SMTP
6 Encoding/Encryption	TLS, JPEG
5 Sessions	NetBIOS, PPTP
4 App-2-App transport	TCP, UDP
3 Routing/IP delivery	IP, ICMP
2 MAC/Frames/ARP	Ethernet, ARP
1 Bits/signals	UTP, Fiber, Wi-Fi

⚡ Common Attacks Per Layer

- **L1:** Sniffing, Jamming
 - **L2:** ARP Spoofing, VLAN Hopping, CAM Flood
 - **L3:** IP Spoofing, Teardrop, ICMP Tunnels
 - **L4:** SYN Flood, TCP Hijack, UDP Reflection
 - **L7:** DNS Poisoning, Phishing, SSL Stripping
 - **Routing:** BGP Hijacking, Blackholing
-

Security Techniques Summary

- **SYN Cookies:** Prevent SYN flood exhaustion
 - **RPKI:** Authenticates BGP announcements
 - **DNSSEC:** Authenticates DNS replies
 - **HSTS:** Forces HTTPS use in browsers
 - **ARP Inspection:** Blocks spoofed ARP replies
 - **Source Port + QID Randomization:** Prevents DNS spoofing
-

TCP Header Flags (Mnemonic: SFA RPU)

- **SYN** – Start
 - **FIN** – Finish
 - **ACK** – Acknowledgment
 - **RST** – Reset
 - **PSH** – Push data
 - **URG** – Urgent
-

MITRE ATT&CK & Pyramid of Pain

- **MITRE TTPs** map adversary techniques to lifecycle stages
 - **Pyramid of Pain:** Higher-level intel (TTPs, Tools) causes more disruption when detected
-

Protocol Ports & Highlights

Protocol Port Notes

HTTP	80	Unencrypted web
HTTPS	443	TLS-secured web
DNS	53	Often abused in DoS, spoofing
SMTP	25	Email sending, can be spoofed

Protocol Port Notes

FTP 21 Unencrypted, risky

NTP 123 UDP-based, used in amplification

End of Practice Exam and Cheatsheet.